EM

HỆ THỐNG QUẢN LÝ NHÂN VIÊN

Tài liệu Kỹ thuật

Ứng dụng Web Full-Stack với Kiểm soát Truy cập theo Vai trò và Ghi nhật ký Kiểm toán Bảo mật

---

Tác giả	Nguyễn Hoàng Việt
Loại Dự án	Ứng dụng Web Full-Stack tập trung vào Bảo mật
Công nghệ	Node.js, Express.js, EJS, MySQL
Demo trực tuyến	https://employee-management-od9a.onrender.com
Phiên bản	1.0 - Tháng 10/2026

Được biên soạn phục vụ thuyết trình dự án, portfolio và đánh giá kỹ thuật.

Mục lục

1. Giới thiệu 3

2. Mục tiêu và Phạm vi Dự án 4

3. Yêu cầu Hệ thống 4

4. Công nghệ Sử dụng 5

5. Kiến trúc Hệ thống 6

6. Thiết kế Cơ sở dữ liệu 7

7. Xác thực và Quản lý Phiên 8

8. Kiểm soát Truy cập theo Vai trò 10

9. Quản lý Nhân viên 11

10. Bảng điều khiển Quản trị 15

11. Quản lý Người dùng 16

12. Ghi nhật ký Kiểm toán 17

13. Các Cơ chế Bảo mật 18

14. Triển khai 19

15. Kiểm thử và Xác minh 20

16. Thách thức và Giải pháp 21

17. Hướng Phát triển 22

18. Kết luận 22

Phụ lục A. Các Route Chính của Ứng dụng 23

Phụ lục B. Biến Môi trường 23

Các ảnh minh họa đã được chèn trực tiếp vào tài liệu. Khi thay ảnh, nên giữ kích thước tương đương để hạn chế thay đổi bố cục và số trang.

1. Giới thiệu

1.1 Tổng quan Dự án

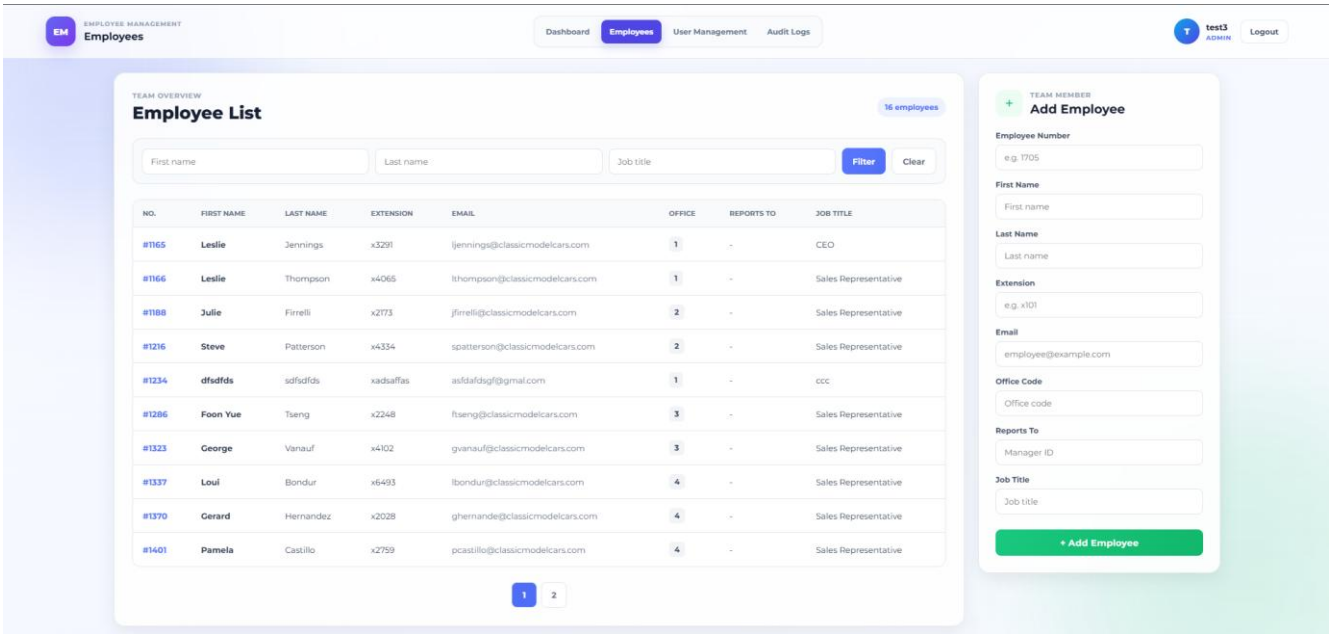
Hệ thống Quản lý Nhân viên là một ứng dụng web full-stack được phát triển để quản lý nhân viên, người dùng ứng dụng, quyền truy cập và các hoạt động quản trị thông qua một giao diện tập trung. Ứng dụng được xây dựng bằng Node.js, Express.js, EJS và MySQL, đồng thời được triển khai dưới dạng một ứng dụng web công khai.

Hệ thống hỗ trợ ba vai trò: Employee, Manager và Admin. Mỗi vai trò được gán một tập quyền khác nhau. Ngoài các thao tác CRUD nhân viên cơ bản, ứng dụng còn cung cấp bảng điều khiển quản trị, quản lý vai trò người dùng, phiên đăng nhập lưu bền vững, nhật ký kiểm toán bảo mật, các HTTP security header, rate limiting và Content Security Policy.

1.2 Động lực Thực hiện Dự án

Một ứng dụng quản lý nhân viên cơ bản thường chỉ tập trung vào việc lưu trữ và chỉnh sửa dữ liệu nhân viên. Tuy nhiên, một hệ thống thực tế hơn còn phải kiểm soát ai được phép thực hiện các thao tác nhạy cảm, duy trì phiên xác thực, ghi lại các hoạt động quan trọng và cung cấp cho quản trị viên khả năng theo dõi hành vi của hệ thống.

Vì vậy, dự án này mở rộng một ứng dụng CRUD truyền thống thành một nền tảng quản lý có chú trọng đến bảo mật. Dự án kết hợp các kiến thức phát triển web full-stack với kiểm soát truy cập, giám sát bảo mật và triển khai trên môi trường production.



Hình 1. Tổng quan Admin Dashboard của Hệ thống Quản lý Nhân viên

2. Mục tiêu và Phạm vi Dự án

2.1 Mục tiêu

- Xây dựng hệ thống quản lý nhân viên trên nền web bằng Node.js, Express.js, EJS và MySQL.
- Triển khai chức năng đăng ký, đăng nhập và đăng xuất với mật khẩu được băm.
- Áp dụng Role-Based Access Control (RBAC) cho các vai trò Employee, Manager và Admin.
- Cho phép Manager tạo mới và cập nhật thông tin nhân viên.
- Cho phép Admin xóa nhân viên và quản lý người dùng ứng dụng.
- Cung cấp bảng điều khiển quản trị sử dụng dữ liệu thống kê thực từ cơ sở dữ liệu.
- Ghi lại các sự kiện xác thực và quản trị trong nhật ký kiểm toán.
- Lưu phiên đăng nhập bền vững trong MySQL.
- Bổ sung các cơ chế bảo mật như Helmet, Content Security Policy và rate limiting.
- Triển khai ứng dụng trên Render và sử dụng cơ sở dữ liệu Aiven MySQL.

2.2 Phạm vi Dự án

Dự án tập trung vào quản lý dữ liệu nhân viên, quản lý người dùng ứng dụng, kiểm soát truy cập, theo dõi sự kiện bảo mật và triển khai hệ thống. Đây là dự án phục vụ học tập và portfolio, không phải một nền tảng HR doanh nghiệp hoàn chỉnh.

Ghi chú phạm vi Các chức năng tính lương, chấm công, đánh giá hiệu suất, phê duyệt quy trình HR và liên kết danh tính doanh nghiệp không nằm trong phạm vi hiện tại của dự án.

3. Yêu cầu Hệ thống

3.1 Yêu cầu Chức năng

ID	Yêu cầu
FR01	Người dùng có thể đăng ký tài khoản.
FR02	Người dùng có thể đăng nhập và đăng xuất.
FR03	Người dùng đã xác thực có thể xem thông tin nhân viên.
FR04	Người dùng có thể tìm kiếm và lọc nhân viên.
FR05	Manager có thể thêm nhân viên mới.
FR06	Manager có thể cập nhật thông tin nhân viên.
FR07	Admin có thể xóa nhân viên.
FR08	Admin có thể truy cập Admin Dashboard.
FR09	Admin có thể xem người dùng đã đăng ký trong ứng dụng.
FR10	Admin có thể thay đổi vai trò người dùng.
FR11	Admin có thể xem audit log.

ID	Yêu cầu
FR12	Hệ thống ghi lại các sự kiện xác thực và quản trị.

3.2 Yêu cầu Phi chức năng

- Bảo mật: mật khẩu không được lưu dưới dạng văn bản thuần và các route được bảo vệ phải thực thi kiểm tra phân quyền.
- Khả dụng: giao diện cần nhất quán giữa các trang quản trị chính.
- Tính bền vững: dữ liệu ứng dụng và phiên đăng nhập cần được duy trì sau các lần khởi động lại ứng dụng thông thường.
- Khả năng bảo trì: routes, controllers, middleware, models, views và static assets cần được tách theo đúng trách nhiệm.
- Khả năng quan sát: các sự kiện bảo mật và quản trị quan trọng cần được ghi lại để phục vụ kiểm tra.
- Khả năng triển khai: ứng dụng cần có thể chạy trên môi trường hosting production và sử dụng biến môi trường cho các cấu hình nhạy cảm.

4. Công nghệ Sử dụng

Tầng	Công nghệ	Mục đích
Backend	Node.js	Môi trường chạy JavaScript phía server.
Web Framework	Express.js	Xử lý routing, middleware, HTTP request và luồng ứng dụng.
View Engine	EJS	Render các trang HTML động phía server.
Frontend	HTML5 / CSS3 / JavaScript	Cấu trúc giao diện, style và hành vi phía client.
Biểu đồ	Chart.js	Trực quan hóa số liệu thống kê trên Dashboard.
Cơ sở dữ liệu	MySQL	Lưu dữ liệu nhân viên, người dùng, session và audit.
Mật khẩu	bcrypt	Băm và xác minh mật khẩu người dùng.
Phiên	express-session + express-mysql-session	Duy trì phiên xác thực trong MySQL.
Security Headers	Helmet	Cấu hình các HTTP security header và CSP.
Rate Limiting	express-rate-limit	Giới hạn các request lặp lại tới endpoint xác thực.
Hosting	Render	Host ứng dụng web Node.js.
Cơ sở dữ liệu được Quản lý	Aiven MySQL	Host cơ sở dữ liệu MySQL production.

5. Kiến trúc Hệ thống

5.1 Mô hình Kiến trúc

Ứng dụng áp dụng cách tổ chức theo phong cách MVC để tách biệt trách nhiệm. Express routes ánh xạ các HTTP request đến các hàm controller. Middleware thực hiện xác thực, phân quyền và bảo vệ request. Controller điều phối logic ứng dụng và gọi các hàm model/query. Model giao tiếp với MySQL, trong khi EJS view render nội dung HTML trả về cho người dùng.

Tầng	Trách nhiệm Chính
Routes	Ánh xạ URL và HTTP method tới action của controller.
Middleware	Xác thực, kiểm tra vai trò, rate limiting và xử lý request.
Controllers	Điều phối việc xử lý request và logic ứng dụng.
Models / Queries	Thực thi truy vấn SQL với MySQL.
Views	Render trang EJS phía server.
Public Assets	Phục vụ CSS và JavaScript phía client.

5.2 Luồng Xử lý Request Điển hình

1. Người dùng gửi HTTP request từ trình duyệt.

2. Express ánh xạ request tới route phù hợp.

3. Middleware xác thực và phân quyền kiểm tra người dùng có được phép tiếp tục hay không.

4. Controller kiểm tra request và gọi hàm model/query cần thiết.

5. Model giao tiếp với MySQL.

6. Controller render EJS view hoặc chuyển hướng người dùng.

7. Trình duyệt nhận HTML response được tạo ra.

6. Thiết kế Cơ sở dữ liệu

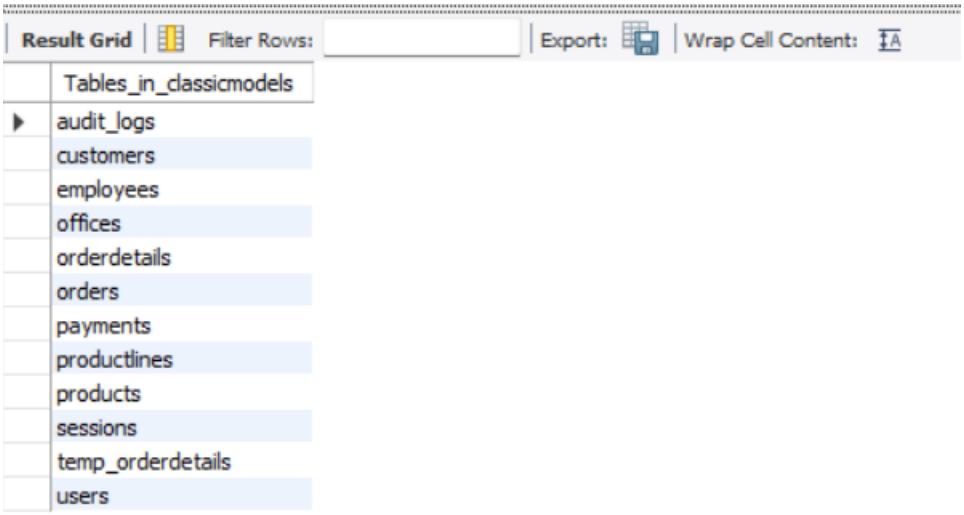
6.1 Các Thực thể Dữ liệu Chính

Ứng dụng sử dụng MySQL làm hệ quản trị cơ sở dữ liệu quan hệ chính. Các thực thể quan trọng nhất ở tầng ứng dụng gồm employees, users, audit_logs và sessions.

Bảng	Mục đích
employees	Lưu hồ sơ nhân viên và thông tin tổ chức.
users	Lưu tài khoản ứng dụng, password hash, liên kết nhân viên và vai trò.
audit_logs	Lưu các sự kiện bảo mật liên quan đến xác thực và quản trị.
sessions	Lưu dữ liệu session Express bền vững.

6.2 Cấu trúc Audit Log

Cột	Mô tả
id	Mã định danh duy nhất của sự kiện audit.
user_id	ID người dùng ứng dụng khi có.
username	Tên người dùng liên quan đến sự kiện.
action	Loại sự kiện như LOGIN_FAILED hoặc EMPLOYEE_UPDATED.
target	Đối tượng bị tác động bởi hành động.
ip_address	Địa chỉ IP nguồn được ứng dụng ghi lại.
created_at	Thời điểm tạo sự kiện.



Hình 2. Sơ đồ cơ sở dữ liệu / các bảng chính của ứng dụng

7. Xác thực và Quản lý Phiên

7.1 Đăng ký và Đăng nhập

Người dùng xác thực bằng tài khoản ứng dụng. Mật khẩu được xử lý bằng bcrypt để cơ sở dữ liệu lưu password hash thay vì mật khẩu dạng văn bản thuần. Khi đăng nhập, mật khẩu người dùng nhập vào được so sánh với hash đã lưu trước khi hệ thống tạo phiên xác thực.

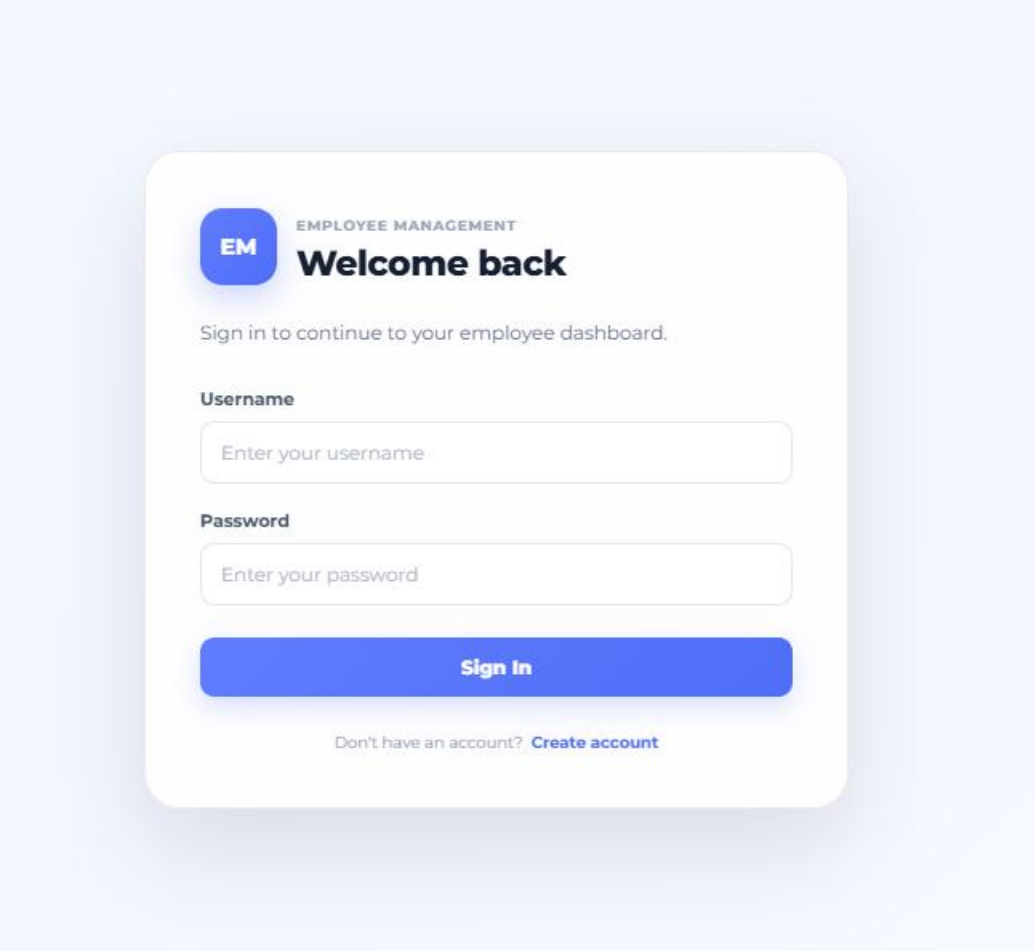
7.2 Lưu trữ Phiên

Ứng dụng sử dụng express-session kết hợp với express-mysql-session. Dữ liệu phiên được lưu trong MySQL thay vì chỉ lưu trong bộ nhớ của ứng dụng, giúp duy trì phiên tốt hơn sau các lần khởi động lại server thông thường và phù hợp hơn với môi trường triển khai.

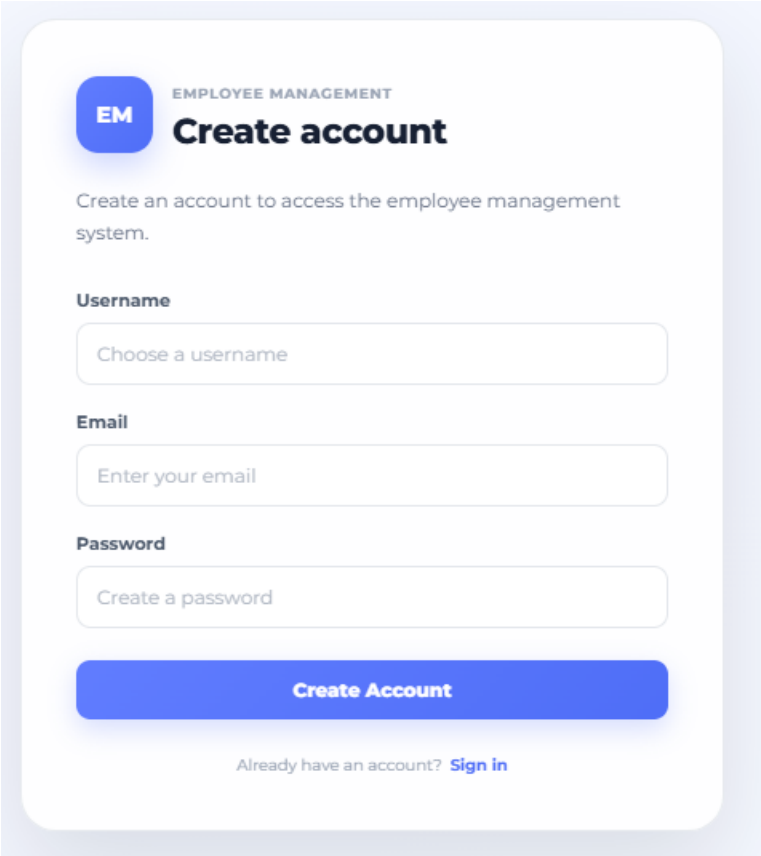
7.3 Cấu hình Session Cookie

- httpOnly ngăn JavaScript phía client thông thường đọc session cookie.

- sameSite=lax giảm một số ngữ cảnh cross-site request nhưng vẫn giữ được hành vi điều hướng phổ biến.
- secure được bật trên production để session cookie chỉ được truyền qua HTTPS.
- Thời gian sống tối đa của phiên được cấu hình để giới hạn thời lượng đăng nhập.



Hình 3. Giao diện đăng nhập



Hình 4. Giao diện đăng ký

8. Kiểm soát Truy cập theo Vai trò

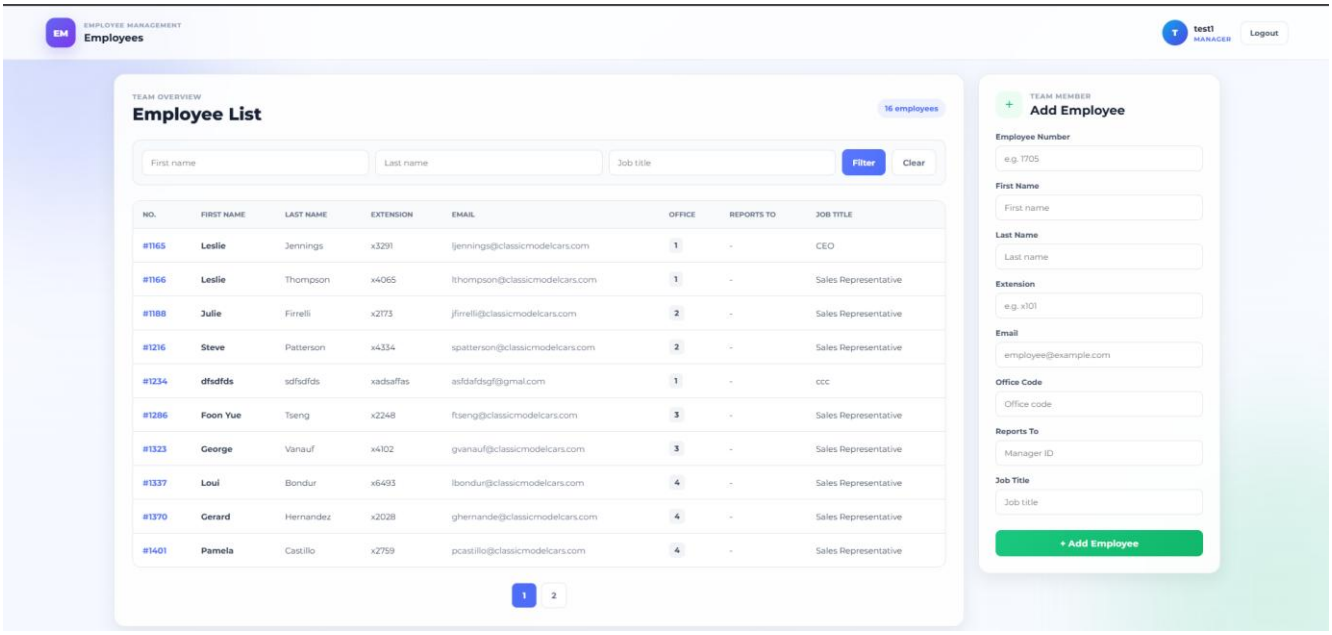
8.1 Các Vai trò

Phân quyền dựa trên ba vai trò của ứng dụng. Vai trò được gắn với phiên đã xác thực sẽ quyết định route và hành động giao diện nào người dùng được phép sử dụng.

Chức năng	Employee	Manager	Admin
Xem nhân viên	Có	Có	Có
Tìm kiếm / Lọc nhân viên	Có	Có	Có
Thêm nhân viên	Không	Có	Có
Chỉnh sửa nhân viên	Không	Có	Có
Xóa nhân viên	Không	Không	Có
Admin Dashboard	Không	Không	Có
User Management	Không	Không	Có
Thay đổi vai trò người dùng	Không	Không	Có
Xem Audit Logs	Không	Không	Có

8.2 Cơ chế Thực thi

Phân quyền được thực thi phía server thông qua middleware xác thực và kiểm tra vai trò, chứ không chỉ bằng cách ẩn nút trên giao diện. Điều này quan trọng vì việc chỉ ẩn thành phần phía client không phải là một biện pháp bảo mật thực sự.

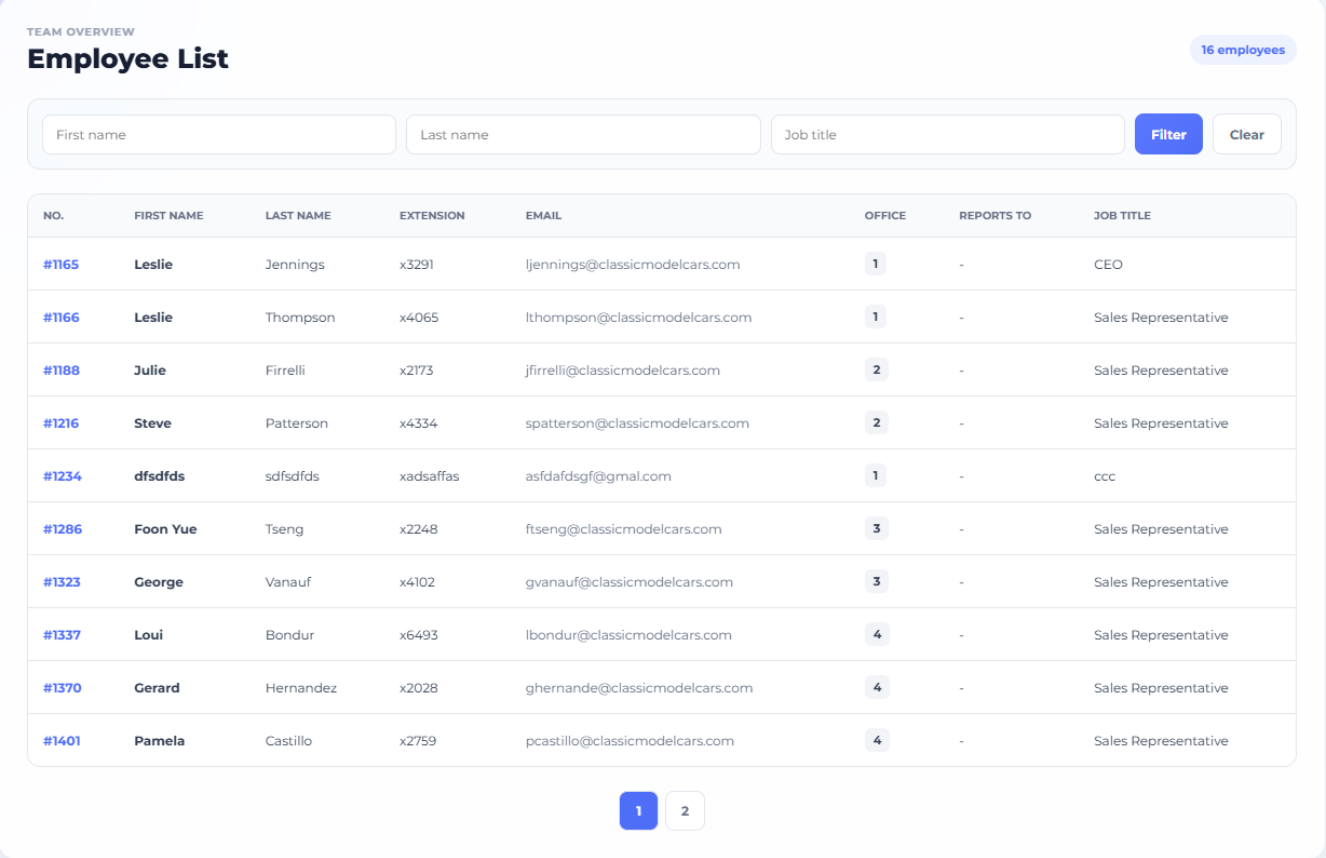


Hình 5. Sự khác biệt giao diện theo vai trò

9. Quản lý Nhân viên

9.1 Danh sách và Lọc Nhân viên

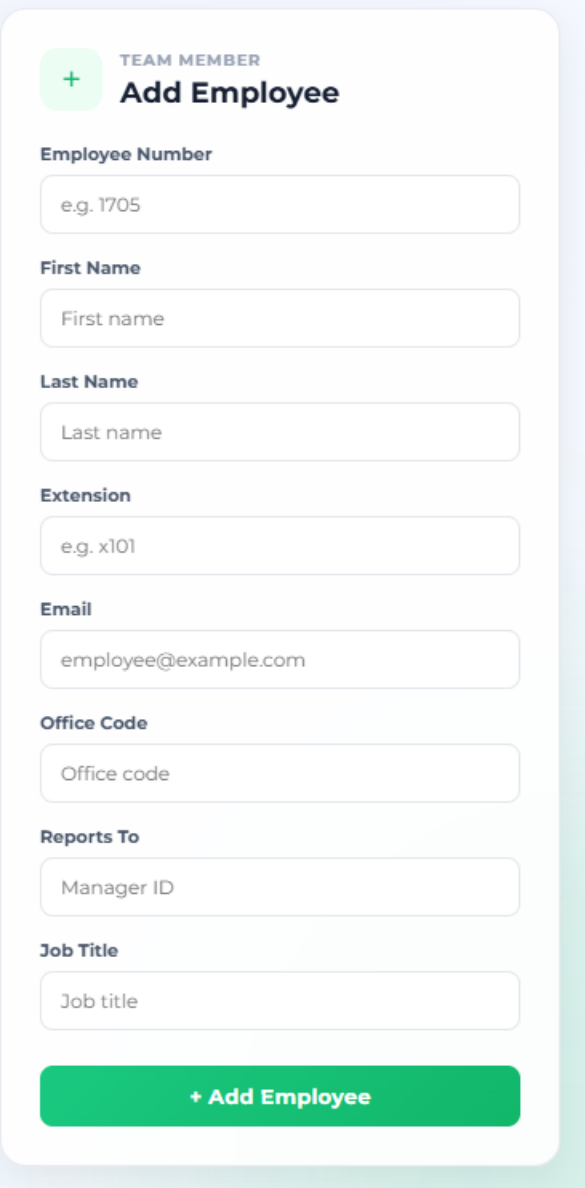
Người dùng đã xác thực có thể xem dữ liệu nhân viên dưới dạng bảng. Các bộ lọc/tìm kiếm cho phép thu hẹp kết quả theo thuộc tính nhân viên, trong khi phân trang giúp quản lý danh sách dữ liệu lớn.



Hình 6. Giao diện danh sách và lọc nhân viên

9.2 Thêm Nhân viên

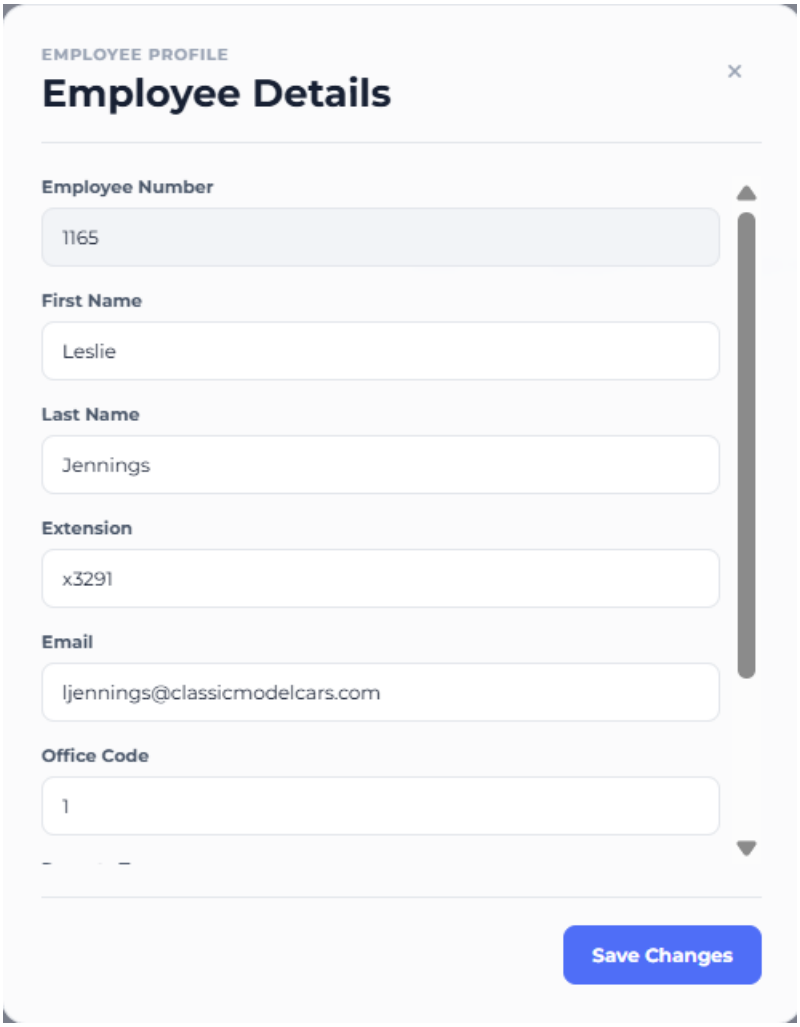
Manager và Admin có thể tạo bản ghi nhân viên mới bằng form Add Employee. Các trường bắt buộc được gửi tới server và chèn vào MySQL thông qua tầng model/query.



Hình 7. Form thêm nhân viên

9.3 Chỉnh sửa Nhân viên

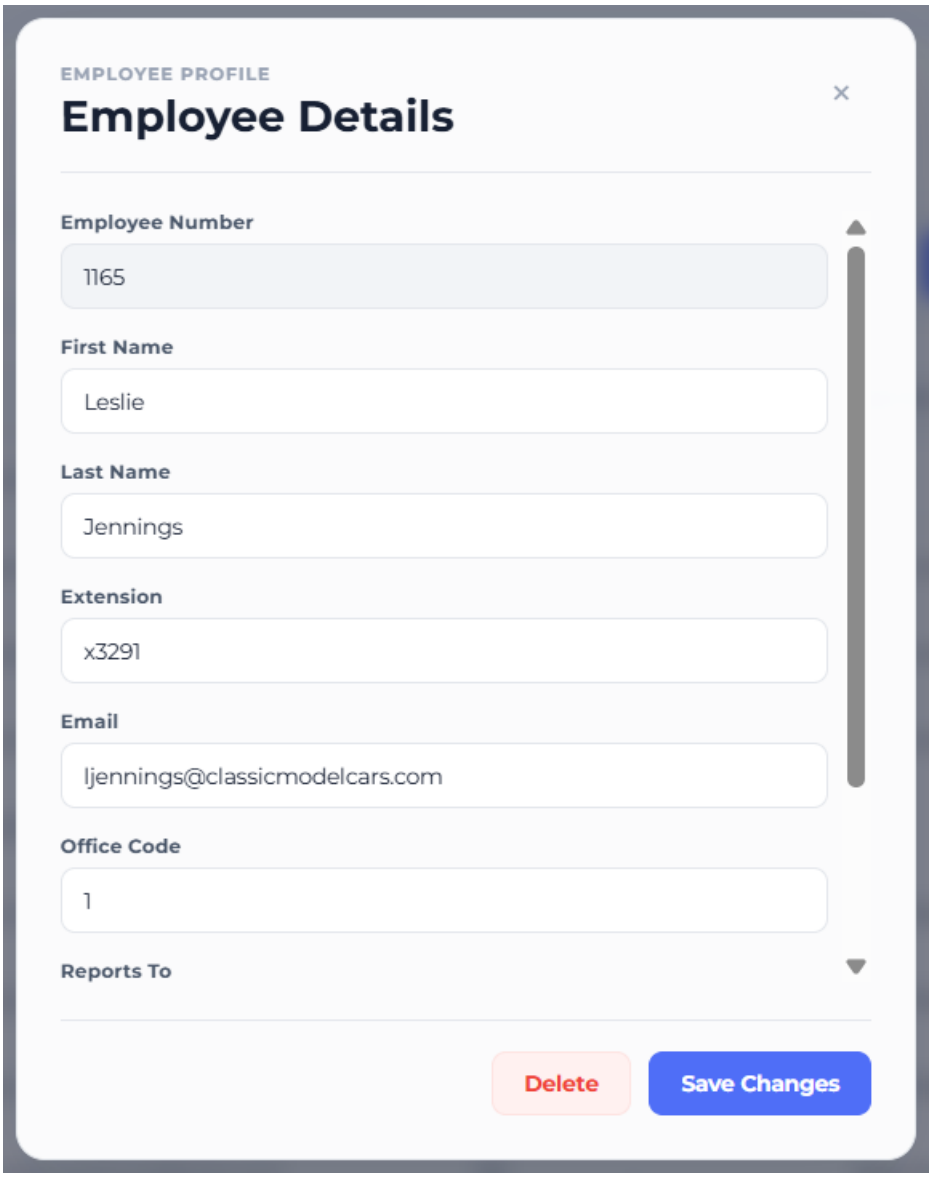
Manager và Admin có thể mở một bản ghi nhân viên và cập nhật thông tin. Giao diện chỉnh sửa tải dữ liệu của nhân viên đã chọn vào modal trước khi các thay đổi được gửi tới server.



Hình 8. Modal chỉnh sửa nhân viên

9.4 Xóa Nhân viên

Chức năng xóa nhân viên chỉ dành cho Admin. Hệ thống hiển thị hộp thoại xác nhận trước khi thực hiện thao tác xóa nhằm giảm nguy cơ xóa nhầm.



Hình 9. Xác nhận xóa nhân viên

10. Bảng điều khiển Quản trị

10.1 Mục đích của Dashboard

Admin Dashboard cung cấp cái nhìn tổng quan tập trung về nhân viên, người dùng và hoạt động bảo mật dựa trên dữ liệu truy vấn từ MySQL. Trang này chỉ dành cho Admin.

10.2 Các Chỉ số Tổng quan

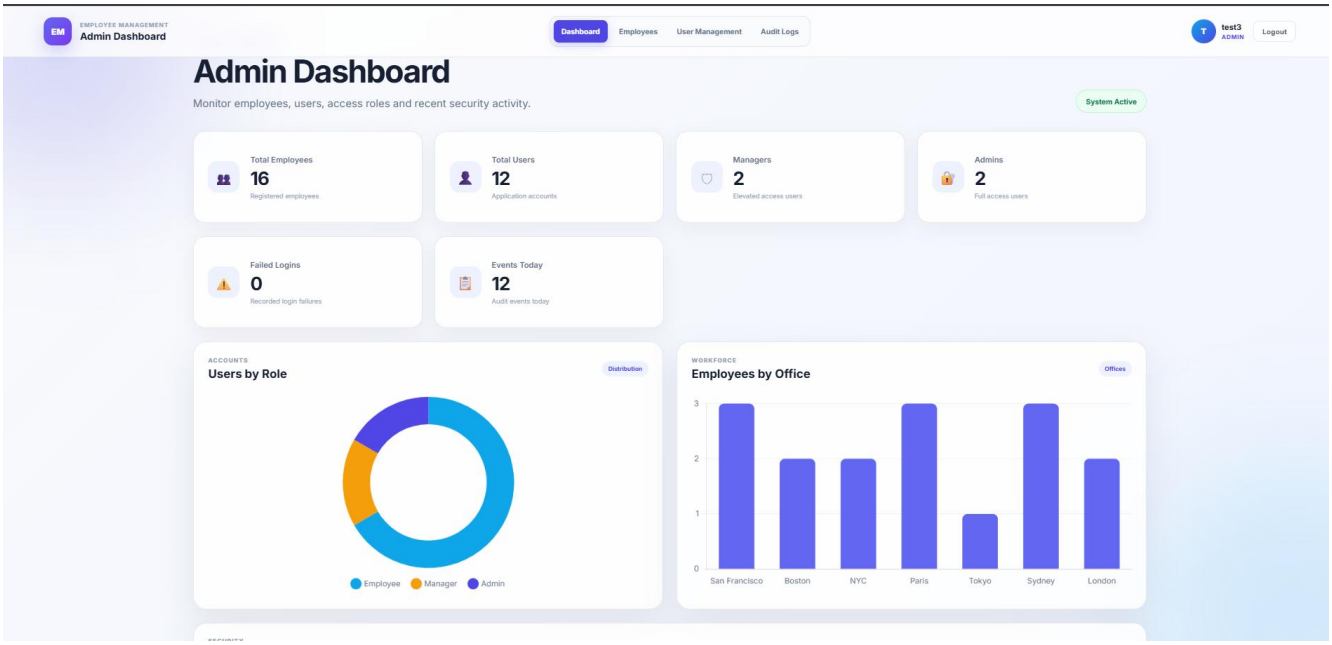
- Tổng số Nhân viên
- Tổng số Người dùng
- Số lượng Manager
- Số lượng Admin
- Số lần Đăng nhập Thất bại

- Sự kiện Bảo mật Hôm nay

10.3 Biểu đồ

- Người dùng theo vai trò - biểu đồ doughnut.
- Nhân viên theo văn phòng - biểu đồ cột sử dụng tên văn phòng.
- Hoạt động Audit - biểu đồ đường trong 7 ngày gần nhất.
- Sự kiện Audit theo hành động - biểu đồ cột nhóm theo loại sự kiện.

JavaScript của Dashboard được lưu trong một file static riêng thay vì dùng các đoạn script inline. Cách này hỗ trợ Content Security Policy chặt chẽ hơn vì không cần sử dụng script-src unsafe-inline.



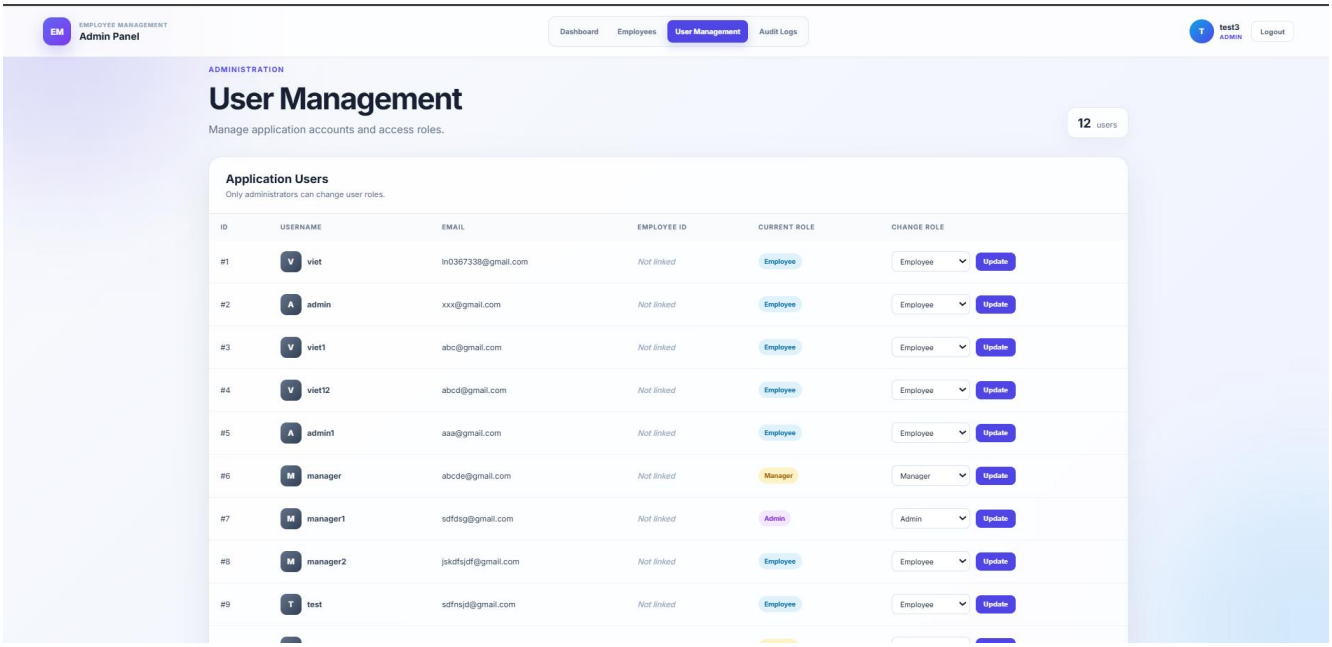
Hình 10. Admin Dashboard với thống kê và biểu đồ dữ liệu thực

11. Quản lý Người dùng

11.1 Quản trị Người dùng

Trang User Management cho phép Admin xem các tài khoản đã đăng ký, kiểm tra employee ID được liên kết, xem vai trò hiện tại và thay đổi vai trò người dùng khi cần.

Admin đang đăng nhập được bảo vệ khỏi việc vô tình tự thay đổi vai trò của chính mình thông qua giao diện quản lý vai trò thông thường.



Hình 11. Giao diện Quản lý Người dùng dành cho Admin

11.2 Khả năng Theo dõi Thay đổi Vai trò

Khi Admin thay đổi vai trò của người dùng, ứng dụng ghi một sự kiện USER_ROLE_UPDATED vào audit log. Target của sự kiện xác định người dùng bị tác động và lưu lại vai trò cũ cùng vai trò mới.

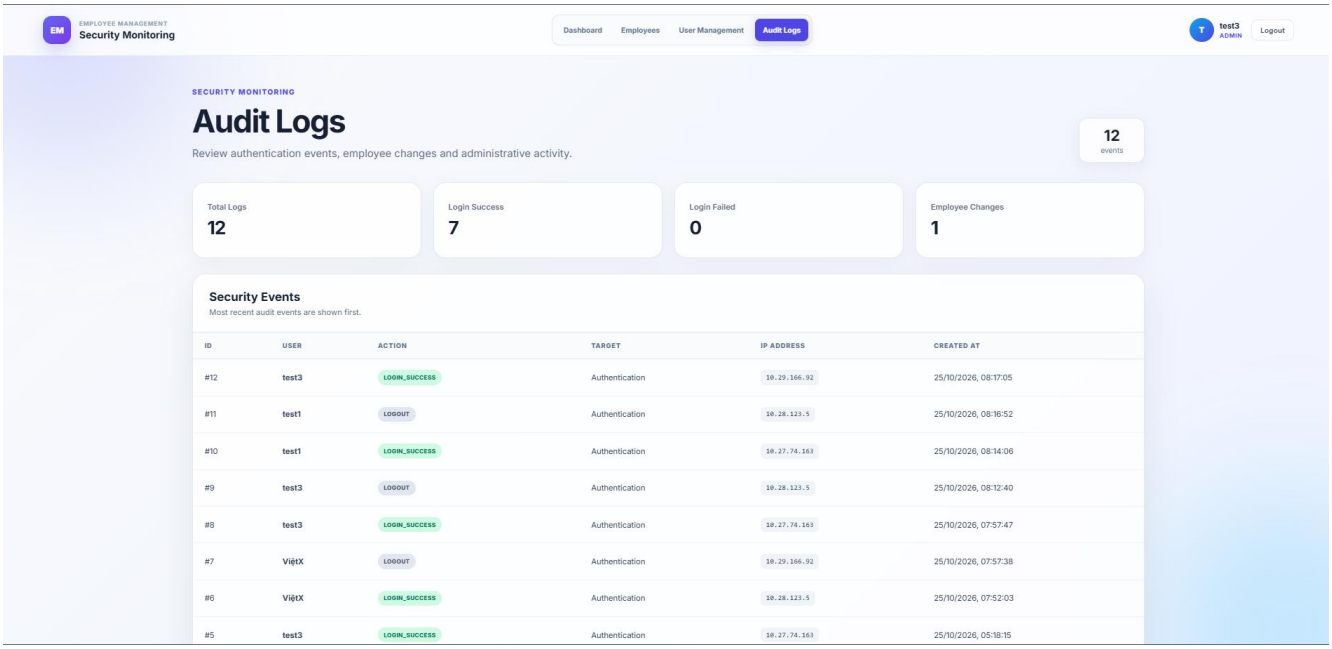
12. Ghi nhật ký Kiểm toán

12.1 Mục đích

Audit logging cung cấp khả năng theo dõi các hành động bảo mật và quản trị quan trọng. Admin có thể kiểm tra điều gì đã xảy ra, người dùng nào liên quan, đối tượng bị tác động, địa chỉ IP nguồn và thời điểm sự kiện diễn ra.

12.2 Các Loại Sự kiện Được Ghi nhận

Sự kiện	Ý nghĩa
LOGIN_SUCCESS	Xác thực thành công.
LOGIN_FAILED	Lần xác thực thất bại.
LOGOUT	Người dùng đã xác thực đăng xuất.
EMPLOYEE_CREATED	Bản ghi nhân viên được tạo.
EMPLOYEE_UPDATED	Bản ghi nhân viên được chỉnh sửa.
EMPLOYEE_DELETED	Bản ghi nhân viên bị xóa.
USER_ROLE_UPDATED	Vai trò người dùng ứng dụng được thay đổi.



Hình 12. Các sự kiện audit bảo mật và quản trị

13. Các Cơ chế Bảo mật

13.1 Bảo vệ Mật khẩu

bcrypt được sử dụng để băm mật khẩu trước khi lưu. Khi đăng nhập, mật khẩu người dùng nhập được so sánh với password hash đã lưu.

13.2 HTTP Security Headers

Helmet được sử dụng để cấu hình các HTTP header liên quan đến bảo mật. Ứng dụng cũng định nghĩa Content Security Policy nhằm giới hạn nguồn được phép tải script, style, font, hình ảnh và các kết nối mạng.

13.3 Content Security Policy

Chính sách hiện tại cho phép script của ứng dụng từ cùng origin và Chart.js từ jsDelivr. Mã Dashboard đã được chuyển sang file JavaScript static bên ngoài để script-src không cần unsafe-inline. Ứng dụng vẫn cho phép inline style ở những vị trí cần thiết theo thiết kế frontend hiện tại.

13.4 Rate Limiting

Các endpoint đăng nhập và đăng ký sử dụng express-rate-limit. Login limiter giảm số lần xác thực lặp lại trong một khoảng thời gian, giúp hạn chế hành vi brute-force tự động. Các lần đăng nhập thành công được bỏ qua trong cấu hình login limiter tập trung vào các lần thử thất bại.

13.5 Phân quyền Phía Server

Các route nhạy cảm được bảo vệ bằng middleware xác thực và kiểm tra vai trò. Điều này ngăn các hành động trái phép ngay cả khi người dùng cố gắng truy cập trực tiếp URL được bảo vệ.

13.6 Giám sát Sự kiện Bảo mật

Các sự kiện đăng nhập thành công/thất bại, thay đổi nhân viên, đăng xuất và thay đổi vai trò người dùng được lưu trong audit log và hiển thị trên giao diện quản trị cũng như Dashboard.

Giới hạn hiện tại CSRF protection chưa nằm trong phiên bản ổn định hiện tại. Tính năng này được đưa vào phần hướng phát triển để có thể tích hợp đầy đủ form token và thực hiện regression testing.

14. Triển khai

14.1 Môi trường Production

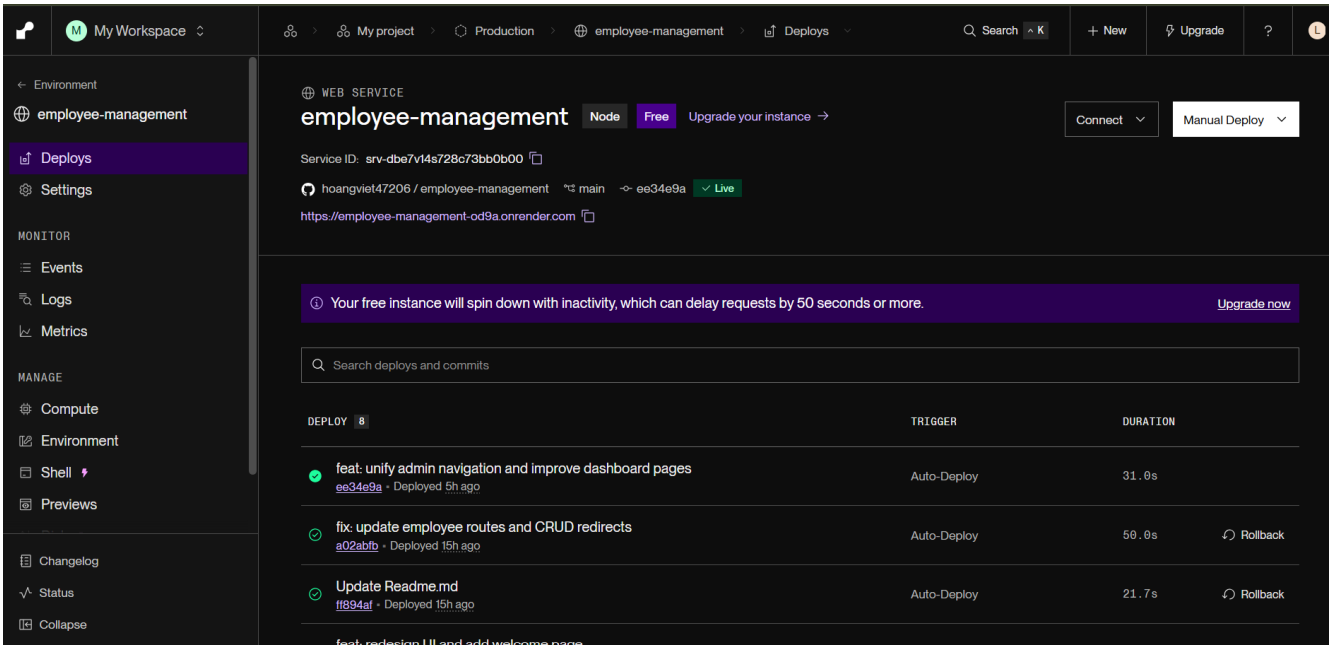
Ứng dụng web được triển khai trên Render. Cơ sở dữ liệu MySQL production được host trên Aiven. Các cấu hình nhạy cảm như thông tin đăng nhập cơ sở dữ liệu và session secret được cung cấp thông qua biến môi trường thay vì hard-code trong source code.

Demo trực tuyến:

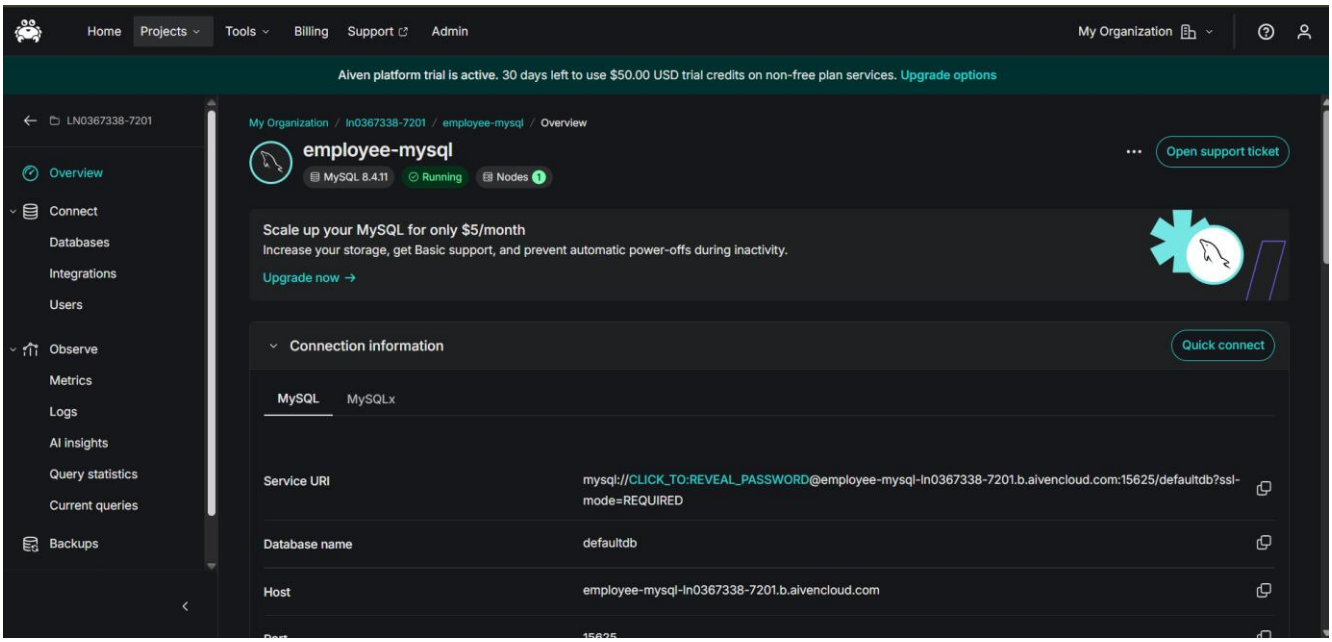
https://employee-management-od9a.onrender.com

14.2 Luồng Triển khai

1. Source code được push lên Git repository.
2. Render build và khởi chạy ứng dụng Node.js.
3. Các biến môi trường production cung cấp cấu hình database và session.
4. Ứng dụng kết nối tới Aiven MySQL.
5. Người dùng truy cập ứng dụng qua HTTPS thông qua URL được triển khai trên Render.



Hình 13. Triển khai production trên Render



Hình 14. Cơ sở dữ liệu MySQL được quản lý trên Aiven

15. Kiểm thử và Xác minh

15.1 Các Ca Kiểm thử Chức năng

Kiểm thử	Kết quả Mong đợi	Trạng thái
Đăng nhập hợp lệ	Phiên xác thực được tạo và người dùng được chuyển hướng.	Đạt
Mật khẩu không hợp lệ	Đăng nhập bị từ chối và sự kiện LOGIN_FAILED được ghi lại.	Đạt
Employee xem danh sách nhân viên	Có thể truy cập danh sách nhân viên.	Đạt
Employee truy cập trang Admin	Truy cập bị từ chối.	Đạt
Manager thêm nhân viên	Nhân viên được tạo và sự kiện audit được ghi lại.	Đạt
Manager chỉnh sửa nhân viên	Nhân viên được cập nhật và sự kiện audit được ghi lại.	Đạt
Manager xóa nhân viên	Thao tác không được phép.	Đạt
Admin xóa nhân viên	Nhân viên được xóa sau khi xác nhận.	Đạt
Admin thay đổi vai trò người dùng	Vai trò được cập nhật và USER_ROLE_UPDATED được ghi lại.	Đạt
Admin mở Dashboard	Các chỉ số và biểu đồ Dashboard được hiển thị.	Đạt
Đăng xuất	Phiên bị kết thúc và LOGOUT được ghi lại.	Đạt

15.2 Xác minh Liên quan đến Bảo mật

- Xác minh người dùng không phải Admin không thể truy cập /admin/dashboard, /admin/users hoặc /audit-logs.
- Xác minh Manager và Employee không thể thực hiện thao tác xóa chỉ dành cho Admin.
- Xác minh các lần đăng nhập thất bại xuất hiện trong audit log.
- Xác minh các request đăng nhập lặp lại cuối cùng sẽ kích hoạt rate limiting.
- Xác minh session cookie được cấu hình an toàn trên production.
- Xác minh các script của Dashboard hoạt động đúng dưới Content Security Policy đã cấu hình.

16. Thách thức và Giải pháp

Thách thức	Giải pháp
Duy trì xác thực sau khi triển khai	Chuyển session storage từ bộ nhớ ứng dụng sang MySQL bằng express-mysql-session.
Nhu cầu phân quyền theo vai trò	Bổ sung middleware xác thực và vai trò, đồng thời thực thi phân quyền trên các route được bảo vệ.
Nhu cầu theo dõi hoạt động quản trị	Bổ sung bảng audit_logs và ghi sự kiện cho xác thực, thay đổi nhân viên và thay đổi vai trò.
Dashboard cần dữ liệu thực	Bổ sung các truy vấn tổng hợp ở tầng model và kết nối dữ liệu với biểu đồ Chart.js.
Biểu đồ Office ban đầu hiển thị mã thay vì tên dễ đọc	Join mã văn phòng của nhân viên với dữ liệu office để nhãn biểu đồ hiển thị tên văn phòng.
Content Security Policy xung đột với JavaScript inline trên Dashboard	Chuyển logic biểu đồ sang file public/scripts/admin-dashboard.js riêng và siết chặt script-src.
Các trang Admin có kiểu navigation khác nhau	Tạo admin-navigation.css dùng chung và chuẩn hóa navigation trên Dashboard, Employees, User Management và Audit Logs.
Việc tích hợp CSRF ảnh hưởng tới các form CRUD hiện có trong quá trình phát triển	Quay lại luồng form ổn định và giữ CSRF protection trong phần hướng phát triển cho tới khi tích hợp và kiểm thử đầy đủ.

17. Hướng Phát triển

- Hoàn thiện CSRF protection cho tất cả form làm thay đổi trạng thái.
- Bổ sung luồng đặt lại mật khẩu bằng token an toàn có thời hạn.
- Xác minh email cho các tài khoản mới đăng ký.
- Bổ sung tìm kiếm audit log nâng cao, lọc theo ngày và loại sự kiện.
- Cho phép xuất audit log để báo cáo hoặc phân tích.
- Xây dựng trang hồ sơ nhân viên với thông tin chi tiết hơn.
- Bổ sung các phân tích Dashboard và so sánh xu hướng.
- Bổ sung kiểm thử unit, integration và authorization tự động.
- Bổ sung cấu hình Docker Compose để triển khai local có thể tái lập.

- Xây dựng pipeline CI/CD cho kiểm thử và triển khai tự động.
- Bổ sung khóa tài khoản hoặc cơ chế thích ứng đối với các lần xác thực thất bại liên tiếp.
- Áp dụng chính sách mật khẩu mạnh hơn và chức năng đổi mật khẩu.

18. Kết luận

Hệ thống Quản lý Nhân viên cho thấy một ứng dụng CRUD sử dụng cơ sở dữ liệu có thể được mở rộng với xác thực, phân quyền, phiên lưu bền vững, giám sát bảo mật, phân tích quản trị và triển khai production. Dự án kết hợp các khái niệm phát triển web và bảo mật trong một ứng dụng thực tế.

Hệ thống hoàn thiện hỗ trợ ba mức quyền, cho phép quản trị người dùng và nhân viên, ghi lại các hoạt động quan trọng để kiểm tra về sau và tích hợp nhiều cơ chế phòng thủ. Đây cũng là nền tảng để tiếp tục phát triển CSRF protection, kiểm thử tự động, tăng cường bảo mật tài khoản và mở rộng khả năng giám sát.

Phụ lục A. Các Route Chính của Ứng dụng

Route	Mục đích	Quyền truy cập
/	Trang chủ / chào mừng	Công khai
/login	Giao diện đăng nhập	Công khai
/register	Giao diện đăng ký	Công khai
/employees	Quản lý nhân viên	Đã xác thực
/admin/dashboard	Bảng điều khiển quản trị	Admin
/admin/users	Quản lý người dùng và vai trò	Admin
/audit-logs	Xem audit log	Admin

Phụ lục B. Biến Môi trường

Biến	Mục đích
DB_HOST	Host cơ sở dữ liệu MySQL.
DB_PORT	Port cơ sở dữ liệu MySQL.
DB_USER	Tên người dùng MySQL.
DB_PASSWORD	Mật khẩu MySQL.
DB_NAME	Tên cơ sở dữ liệu của ứng dụng.
SESSION_SECRET	Secret dùng để ký dữ liệu session.
NODE_ENV	Môi trường chạy như development hoặc production.
PORT	HTTP port của ứng dụng.

Nhắc nhở bảo mật Không bao giờ đưa mật khẩu thật, connection string, session secret hoặc thông tin xác thực production vào ảnh chụp, tài liệu, README hay Git repository.

Các ảnh minh họa đã được chèn trực tiếp vào tài liệu. Khi thay thế ảnh, hãy giữ caption ngay bên dưới và sử dụng kích thước ảnh tương đương để hạn chế thay đổi bố cục trang.